

1. BUFFER OVERFLOW ATTACK

DEFINITION
A buffer overflow occurs when a program writes more data to a buffer than it was designed to hold, causing the program to overwrite adjacent memory locations and potentially crash or execute arbitrary code.

HOW BUFFER OVERFLOW OCCURS
A buffer is a fixed-size area of memory. If a program writes more data to a buffer than it was designed to hold, the data will overflow the buffer and overwrite adjacent memory locations. This can cause the program to crash or execute arbitrary code.

EXAMPLES OF BUFFER OVERFLOW

- Stack Overflow:** A buffer overflow on the stack can cause a program to crash or execute arbitrary code.
- Heap Overflow:** A buffer overflow on the heap can cause a program to crash or execute arbitrary code.

2. SPOOFING AND SNIFFING ATTACKS

DEFINITION
Spoofing is an attack where an attacker impersonates a legitimate entity to gain unauthorized access to a system. Sniffing is an attack where an attacker intercepts and steals sensitive information transmitted over a network.

HOW SPOOFING AND SNIFFING ATTACKS OCCUR

- Spoofing:** An attacker impersonates a legitimate entity to gain unauthorized access to a system.
- Sniffing:** An attacker intercepts and steals sensitive information transmitted over a network.

3. SCUTS PROTOCOL WORKING

DEFINITION
SCUTS (Secure Communication Using Trusted Third Parties) is a protocol for secure communication between two parties over an insecure channel.

HOW SCUTS PROTOCOL WORKS

- Client and Server establish a connection.
- Client sends a request to the Server.
- Server responds with a message.
- Client and Server establish a secure session.
- Client and Server communicate securely.

1. DES (DATA ENCRYPTION STANDARD)

DEFINITION
DES is a symmetric-key algorithm for encrypting and decrypting data. It uses a 56-bit key to perform a series of operations on the data.

DES ALGORITHM - OVERALL DESIGN

- Input:** Plaintext (P) and Key (K).
- Process:** The plaintext is divided into blocks, and each block is encrypted using the key.
- Output:** Ciphertext (C).

2. COMPARISON: SYMMETRIC VS ASYMMETRIC CRYPTOGRAPHY

Feature	Symmetric Cryptography	Asymmetric Cryptography
Key Management	Simple, but requires a secure way to share the key.	Complex, but allows for secure key exchange.
Performance	Fast, but less secure.	Slower, but more secure.
Use Cases	Used for bulk encryption of data.	Used for secure communication and digital signatures.

3. DIGITAL SIGNATURE

DEFINITION
A digital signature is a cryptographic value that is used to verify the authenticity and integrity of a message.

HOW DIGITAL SIGNATURES WORK

- The sender creates a hash of the message.
- The sender encrypts the hash with their private key.
- The sender sends the message and the encrypted hash.
- The receiver decrypts the hash with the sender's public key.
- The receiver compares the decrypted hash with a new hash of the received message.

1. PHISHING

DEFINITION
Phishing is a social engineering attack where an attacker tricks a user into revealing sensitive information, such as passwords or credit card numbers.

HOW PHISHING WORKS

- Attacker sends a phishing email or message.
- User clicks on a link or provides sensitive information.
- Attacker gains access to the user's account or sensitive information.

2. SESSION HIJACKING

DEFINITION
Session hijacking is an attack where an attacker takes over a valid session between a user and a server.

HOW SESSION HIJACKING WORKS

- Attacker intercepts the session cookie.
- Attacker uses the session cookie to impersonate the user.
- Attacker gains access to the user's account or sensitive information.

3. COOKIES

DEFINITION
A cookie is a small text file stored on a user's device that contains information about the user and the website.

HOW COOKIES WORK

- User visits a website.
- Website sends a cookie to the user's browser.
- User's browser stores the cookie.
- User's browser sends the cookie back to the website.

COOKIE STRUCTURE

Name	Value	Domain	Path	Expires / Max-Age	Secure	HttpOnly	Sandbox
sessionid	1234567890	example.com	/	2024-12-31	Yes	Yes	Yes

1. DIGITAL SIGNATURE

DEFINITION
A digital signature is a cryptographic value that is used to verify the authenticity and integrity of a message.

HOW DIGITAL SIGNATURES WORK

- The sender creates a hash of the message.
- The sender encrypts the hash with their private key.
- The sender sends the message and the encrypted hash.
- The receiver decrypts the hash with the sender's public key.
- The receiver compares the decrypted hash with a new hash of the received message.

2. MAC (MESSAGE AUTHENTICATION CODE)

DEFINITION
A MAC is a short, fixed-length code generated using a secret key and a message.

HOW MACS WORK

- Sender and Receiver share a secret key.
- Sender calculates the MAC of the message.
- Sender sends the message and the MAC.
- Receiver calculates the MAC of the received message.
- Receiver compares the calculated MAC with the received MAC.

3. DOS ATTACKS (DENIAL OF SERVICE)

DEFINITION
A Denial of Service (DoS) attack is an attempt to make a system or network unavailable to its intended users.

HOW DOS ATTACKS WORK

- Attacker sends a flood of traffic to the target system.
- Target system becomes overloaded and unavailable.
- Users are unable to access the system.

1. CROSS-SITE SCRIPTING (XSS)

DEFINITION
Cross-Site Scripting (XSS) is a security vulnerability that allows an attacker to inject malicious scripts into a web page.

HOW XSS WORKS

- Attacker injects a malicious script into a web page.
- User visits the web page.
- User's browser executes the malicious script.
- Attacker gains access to the user's account or sensitive information.

2. FIREWALLS AND THEIR TYPES

DEFINITION
A firewall is a network security device that monitors and controls incoming and outgoing network traffic.

TYPES OF FIREWALLS

- Packet Filtering:** A firewall that filters traffic based on IP addresses and ports.
- Stateful Inspection:** A firewall that tracks the state of active connections.
- Proxy:** A firewall that acts as an intermediary between the client and the server.

3. INTRUSION DETECTION SYSTEM (IDS)

DEFINITION
An Intrusion Detection System (IDS) is a security system that monitors network traffic for signs of malicious activity.

HOW IDS WORKS

- IDS monitors network traffic.
- IDS detects suspicious activity.
- IDS alerts the administrator.

1. RACE CONDITION

DEFINITION
A race condition is a type of error that occurs when the behavior of a system depends on the sequence or timing of uncontrollable events.

HOW RACE CONDITIONS OCCUR

- Two threads access a shared resource.
- The threads perform operations on the shared resource.
- The final state of the shared resource is unpredictable.

2. ACCESS CONTROL PROBLEMS

DEFINITION
Access control problems occur when users are able to access resources or perform operations that they are not authorized to access.

COMMON ACCESS CONTROL PROBLEMS

- Broken Access Control:** A user can access resources they are not authorized to access.
- Privilege Escalation:** A user can gain higher privileges than intended.
- Insufficient Privilege:** A user cannot access resources they are authorized to access.
- Missing Function Level Access Control:** A user can perform actions that are not intended.
- Over-Privilege:** A user has more permissions than necessary.

3. DIFFERENCE BETWEEN SSL AND TLS

DEFINITION
SSL (Secure Sockets Layer) and TLS (Transport Layer Security) are protocols for secure communication over a network.

DIFFERENCES

- SSL:** An older protocol that is no longer recommended.
- TLS:** A newer protocol that is recommended.

4. DNS SECURITY

DEFINITION
DNS Security is the practice of protecting the Domain Name System from attacks and threats.

COMMON DNS THREATS

- DNS Spoofing:** An attacker intercepts and alters DNS traffic.
- DNS Hijacking:** An attacker redirects traffic to a malicious website.
- DNS Amplification:** An attacker uses a DNS server to launch a DDoS attack.
- DNS Tunneling:** An attacker uses a DNS server to exfiltrate data.
- DNS on DNS:** An attacker uses a DNS server to launch a DDoS attack.

Explain SQL Injection attack with prevention A SQL Injection (SQLi) attack occurs when an attacker manipulates a web application's database query by inserting malicious SQL code into an input field. Because the application fails to properly sanitize the user's input, the database interprets the malicious code as part of its command, allowing the attacker to view, modify, or delete sensitive data. 1. How a SQL Injection Works Most web applications use SQL to interact with a database (e.g., to verify a user's login). If the code simply concatenates the input string directly into the query, it is vulnerable. Vulnerable Code Example (PHP): <pre>Susername = \$_POST['username']; // Vulnerable: The input is directly inserted into the query string Squery = "SELECT * FROM users WHERE username = '" . Susername . "'";</pre> The Attack: If an attacker enters ' OR '1'='1 as their username, the resulting query becomes: SELECT * FROM users WHERE username = " OR '1'='1' Because '1'='1' is always true, the database returns all records in the users table, effectively bypassing login requirement and potentially exposing all user data. 2. Types of SQL Injection In-Band SQLi: The attacker uses the same communication channel to launch the attack and gather results. This is the most common and easiest type. Inferential (Blind) SQLi: The attacker sends data to the server and observes the server's response (e.g., true/false behaviors or response time differences) to reconstruct the database structure bit by bit. Out-of-Band SQLi: The attacker triggers the database to send data to an external server they control (usually when primary web server's responses are hidden).	Explain IPSec architecture IPSec (Internet Protocol Security) is a suite of protocols designed to provide security at the Network Layer (Layer 3) of the OSI model. By securing packets at the IP level, it provides a "tunnel" that protects all traffic between two points (such as two routers or a client and a gateway), regardless of the applications being used. 1. The Core Architecture: IPSec does not rely on a single protocol; it uses a framework of complementary protocols to achieve its goals: Authentication Header (AH): Provides connectionless integrity and data origin authentication for IP datagrams. It ensures the data has not been tampered with, but it does not provide encryption. Encapsulating Security Payload (ESP): The most commonly used protocol. It provides confidentiality (encryption), data origin authentication, and anti-replay services. Internet Key Exchange (IKE): The protocol used to set up the security association (SA). It handles the negotiation of keys, authentication of peers, and the setup of the encrypted tunnel. 2. IPSec Modes of Operation Depending on the network requirements, IPSec operates in one of two modes: A. Transport Mode: In this mode, only the payload of the IP packet is encrypted/authenticated. The original IP header is kept intact.	

	Use Case: End-to-end communication between two specific hosts (e.g., a client and a server). Pros: Lower overhead, as it doesn't add an extra IP header. B. Tunnel Mode: In this mode, the entire original IP packet (header + payload) is encrypted and encapsulated inside a new IP packet with a new header. Use Case: Gateway-to-gateway communication (e.g., connecting two corporate offices over the internet via VPN). Pros: Hides the internal network topology from the public internet. 3. The IPSec "Tunneling" Process The establishment of an IPSec connection follows a structured logical flow: Security Association (SA) Negotiation: Using IKE, the two devices agree on the algorithms (e.g., AES for encryption, SHA for hashing) and exchange keys. Traffic Selection: The devices determine which traffic should be protected based on policies (IP addresses, ports, protocols). Encapsulation/Encryption: The outgoing packet is processed by the ESP/AH protocol according to the SA parameters. Transmission: The protected packet is routed through the network. Decapsulation/Decryption: The receiving gateway verifies the integrity, decrypts the payload, and forwards the packet to the destination. 4. Summary of Benefits Transparency: Since it operates at the network layer, applications do not need to be "IPSec-aware." They simply send data as usual, and the network stack handles the security. Granular Control: Security policies can be defined for specific subnets, hosts, or protocols. Strong Integrity: By using HMACs (Hash-based Message Authentication Codes) in ESP or AH, IPSec effectively prevents unauthorized packet modification.	3. Prevention Strategies: Preventing SQL injection is a mandatory standard in secure software development. You should never "trust" user input. A. Parameterized Queries (Prepared Statements): This is the most effective defense. Instead of building a query string, you use a template and send the user input as a separate parameter. The database engine treats the input strictly as data, never as executable code. Secure Code Example (using PDO in PHP): <pre>PHP \$stmt = \$pdo->prepare('SELECT * FROM users WHERE username = :username'); \$stmt->execute(['username' => \$username]); // Input is treated only as data</pre> B. Input Validation and Sanitization Whitelisting: Only allow input that matches a strict pattern (e.g., an age field should only contain integers). Sanitization: Remove or escape dangerous characters (like ', --, or ;) before processing input, though this should be a secondary defense to prepared statements. C. Principle of Least Privilege: Configure the database user account used by the web application to have only the minimum permissions necessary. For example, a login form should only be able to perform SELECT operations on the users table—it should not have permissions to DROP tables or GRANT new privileges. D. Web Application Firewalls (WAF): A WAF can help detect and block common SQL injection patterns in incoming traffic before they even reach your application.